

Security and Access Document (SAD)

CampusFind Pro - System Access, Encryption, and API Security Standards

1. Authentication and Profile Sync

User authentication is performed via Google OAuth 2.0. The callback script (auth/google-callback.php) validates auth tokens against Google's API and extracts user emails, names, and avatars. A remote avatar synchronization routine checks for broken local files and repairs user profile pictures dynamically to ensure they point to live Google hosted URLs.

2. Forms & Request Protection Policies

- **CSRF Prevention:** All state-modifying requests (form submissions, item edits, claim processes) require validation of a secure CSRF token generated per-session.
- **Access Authorization Filters:** Route endpoints are protected using `requireRole('student')` or `requireRole('admin')` session validations, rejecting unauthorized calls.
- **Secure Credentials Store:** Sensitive credentials (database URIs, API keys, SMTP codes) are loaded using `putenv()` from local `.env` files and kept out of Git repositories.